



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



Technical Vulnerability Report(TVR)

In Partial Fulfillment of the Requirements for the Course
Information Assurance & Security

Submitted by:

Ramoel T. Bello
Nicko James Ortencio

Section:

3BSIT-3

Submitted to:

Ram Villarosa

October 23, 2024
1st Semester, A.Y. 2024-2025



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



SQL injection

Vulnerability Name	SQL Injection (SQLi) SQL Injection (SQLi) - Login Bypass
CWE	SQL Injection (SQLi) CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') CWE-89 refers to improper handling of user input in SQL queries, which allows attackers to modify the structure of the SQL commands being executed. SQL Injection (SQLi) - Login Bypass CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') CWE-89 relates to improper input neutralization in SQL queries, which allows attackers to alter the logic of authentication queries, bypassing login forms.



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



CVSS 3.1 Score	SQL Injection (SQLi) -5.3 SQL Injection (SQLi) - Login Bypass -9.8
Severity	SQL Injection (SQLi) -Medium SQL Injection (SQLi) - Login Bypass -Critical
CVSS Vector	SQL Injection (SQLi) AV (Attack Vector: Network) – Exploitable over a network. AC (Attack Complexity: Low) – Simple exploitation. PR (Privileges Required: None) – No authentication needed. UI (User Interaction: None) – No user interaction required. S (Scope: Unchanged) – The exploit only affects the same application. C (Confidentiality: Low) – Access to non-sensitive data. I (Integrity: Low) – Minimal risk of data modification. A (Availability: Low) – No significant impact on availability.



	SQL Injection (SQLi) - Login Bypass AV (Attack Vector: Network) – Exploitable remotely via the web. AC (Attack Complexity: Low) – Easy to exploit with no special conditions. PR (Privileges Required: None) – No prior authentication is needed to exploit. UI (User Interaction: None) – Exploited without user interaction. S (Scope: Unchanged) – The attack remains within the same system. C (Confidentiality: High) – Attackers gain access to highly sensitive data (administrator account). I (Integrity: High) – Attackers can modify critical data (e.g., updating account details like the email). A (Availability: High) – Full administrative access can lead to disruption of services.
Description	SQL Injection (SQLi) SQL Injection happens when a web application doesn't properly handle user inputs in database queries. This allows an attacker to insert malicious SQL code into a field (like a login or search box) to change how the database responds. For example, if the attacker enters something like ' OR '1'=1 into a login field, the application might run this as part of



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



	its SQL query without checking if it's safe. This can trick the database into granting access, even if the user doesn't have valid credentials. SQL Injection (SQLi) - Login Bypass SQL Injection Login Bypass is a type of attack where an attacker manipulates the login input to bypass authentication. This happens when a login form doesn't properly handle special characters, allowing the attacker to modify the SQL query that checks the username and password. For instance, by entering something like "administraror'--" as the username and any random password, the attacker can trick the application into logging them in as an administrator. The "--" sequence in SQL is used to comment out the rest of the query, so the database skips checking for the password.
Security Impact	SQL Injection (SQLi) Data Access: The attacker can view product records from categories that they shouldn't normally access, but the



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



	data itself is not highly sensitive (e.g., no customer information or private data). Data Integrity: There is little to no risk of the attacker altering the data since the payload was only used to view data, not modify it. Application Availability: The availability of the application remains largely unaffected as the query only alters product visibility. SQL Injection (SQLi) - Login Bypass Unauthorized Access: The attacker can gain full access to administrative accounts, allowing them to control the application, modify user information, and perform privileged actions. Data Manipulation: The attacker was able to update account information, such as changing the email address of the administrator account. Service Control: Since administrative privileges were bypassed, the attacker could potentially lock out legitimate users, disrupt services, or perform other malicious activities.
Affected Host(s)	SQL Injection (SQLi)



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



	https://0af5005303e86aa081d87a1500110011.web-security-academy.net SQL Injection (SQLi) - Login Bypass https://0a8d000a03f1860e8150e30d00e900d3.web-security-academy.net/my-account?id=administrator
Remediation	SQL Injection (SQLi) Use Parameterized Queries (Prepared Statements): Ensure that dynamic queries are not constructed directly with user inputs. Use safe methods like parameterized queries to avoid SQL injections. Input Validation: Validate and sanitize all user inputs to only accept valid values for the category parameter. Stored Procedures: Where possible, use stored procedures that limit the ability of user input to directly affect SQL queries. Error Handling: Disable detailed SQL error messages from being exposed to users, as this can help attackers in crafting their payloads. SQL Injection (SQLi) - Login Bypass Use Parameterized Queries (Prepared Statements): Ensure that input is strictly



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila

College of Informatics and Computer Studies



	treated as data, not executable SQL code. Using parameterized queries or prepared statements for authentication can prevent this type of attack. Input Validation: Validate all inputs for special characters like single quotes (') to ensure that only valid inputs are accepted. Limit Error Feedback: Display generic error messages and avoid giving attackers any hints about SQL errors or whether a username exists. Multi-factor Authentication (MFA): Implement MFA as an extra layer of protection for high-privilege accounts. Auditing and Monitoring: Enable logging and monitoring of login attempts to detect suspicious activities, such as multiple failed login attempts or SQL-related errors.
External reference	OWASP SQL Injection PortSwigger SQL Injection Cheat Sheet CWE-89: SQL Injection CVSS Calculator
Documentation	SQL Injection (SQLi)



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



SQL injection vulnerability in W...
WebSecurity Academy
SQL injection vulnerability in WHERE clause allowing retrieval of hidden data
Not solved

WE LIKE TO SHOP

Refine your search:
All Clothing, shoes and accessories Food & Drink Lifestyle Tech gifts

First Impression Costumes
★★★★☆ \$4.51
View details

Portable Hat
★★★★☆ \$59.05
View details

The Alternative Christmas Tree
★★★★☆ \$58.36
View details

BBS Sublime
★★★★☆ \$81.50
View details

SQL injection vulnerability in W...
WebSecurity Academy
SQL injection vulnerability in WHERE clause allowing retrieval of hidden data
Not solved

Internal Server Error
Internal Server Error



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



SQL injection vulnerability

web-security-academy.net

SQL injection vulnerability allowing login bypass

LAB Not solved

Home | My account

WE LIKE TO SHOP



Phantom's Backpack

★★★★☆ \$44.82

View details



Giant Pillow Thing

★★★★☆ \$78.68

View details



The Quiet Enter Key

★★★★☆ \$86.99

View details



Craigh's Umbrella

★★★★☆ \$34.41

View details



Waterproof Tea Bags

★★★★☆ \$12.99

View details



Potion Box

★★★★☆ \$15.99

View details



Six-Pack Beer Box

★★★★☆ \$19.99

View details



Cool Tool

★★★★☆ \$14.99

View details

SQL injection vulnerability

web-security-academy.net/login

SQL injection vulnerability allowing login bypass

LAB Not solved

Home | My account

Login

Username

Password

Log in



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



SQL injection vulnerability

WebSecurity Academy

SQL injection vulnerability allowing login bypass

LAB Not solved

Back to lab description

Home | My account

Login

Username

administrator--

Password

Log in

SQL injection vulnerability

WebSecurity Academy

SQL injection vulnerability allowing login bypass

LAB Solved

Back to lab description

Congratulations, you solved the lab!

Share your skills! | Continue learning

Home | My account | Log out

My Account

Your username is: administrator

Email

Update email



Cross-site scripting

Vulnerability name	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute
CWE ID	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding CWE-79: Improper Neutralization of Input During Web Page Generation ("Cross-Site Scripting") • CWE-79 refers to insufficient neutralization of user-supplied input before incorporating it into a web page, allowing execution of malicious scripts in a victim's browser. DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute CWE-79: Improper Neutralization of Input



	During Web Page Generation ("Cross-Site Scripting") • This CWE describes vulnerabilities where web applications fail to neutralize potentially dangerous input, leading to malicious code execution in the client's browser.
CVSS 3.1 Score	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding -6.1 DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute -6.1
Severity	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding -Medium DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute -Medium
CVSS Vector	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding AV (Attack Vector: Network) – Exploitable over a network. AC (Attack Complexity: Low) – Exploitation is straightforward. PR (Privileges Required: None) – No authentication is required. UI (User Interaction: Required) – Victim



	interaction is necessary (i.e., they need to click a malicious link). S (Scope: Changed) – The impact extends beyond the vulnerable application. C (Confidentiality: Low) – Limited access to sensitive information, typically session data or cookies. I (Integrity: Low) – Limited impact, such as changing displayed content or stealing session tokens. A (Availability: None) – The attack does not directly affect the availability of the application.
	DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute AV (Attack Vector: Network) – Exploitable over a network connection. AC (Attack Complexity: Low) – The exploitation is simple and requires minimal technical skill. PR (Privileges Required: None) – The attacker doesn't need any special privileges. UI (User Interaction: Required) – The victim must interact with the malicious input (like clicking a link or loading the affected page). S (Scope: Changed) – The impact goes beyond the vulnerable component, affecting other parts of the application or user data. C (Confidentiality: Low) – The attacker



	could access sensitive data (e.g., cookies). I (Integrity: Low) – The attacker has limited ability to alter content. A (Availability: None) – There is no impact on availability.
Description	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding This vulnerability happens because the application doesn't correctly handle the data a user puts into it. When an attacker submits harmful input, like a small JavaScript snippet, through a URL or form, the application sends this code right back to the user's browser, showing it on the webpage without checking for unsafe code. For example, if an attacker enters <code><script>alert(1)</script></code> in the URL, the browser will run it as a script, showing a pop-up. Although this seems harmless, attackers can use this trick to run much more damaging code. They could steal the user's cookies, gain session data, or even redirect the user to a fake page. DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute The vulnerability happens because of the website that doesn't check what's entered in the search bar before inserting it into



	the img src attribute. This lack of checking allows me to add code that alters how the page behaves. For example, I could enter something like "<svg onload=alert(1)>", which "breaks out" of the img tag and adds a new element with a JavaScript action. This code triggers a pop-up (or other actions) because the website isn't blocking potentially harmful input.
Security Impact	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding • Session Hijacking: The attacker can steal cookies or session tokens to impersonate the victim and access their account. • Phishing: The attacker can inject malicious scripts that lead the victim to fake pages, tricking them into providing sensitive information. • Malicious Redirection: The attacker can redirect the victim to an external site under their control. • Content Manipulation: The attacker can alter the visual content of the webpage, misleading users or defacing the site.



	DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute • Session Hijacking: The attacker can access session cookies or tokens, allowing impersonation of the user. • Data Theft: Sensitive information might be accessed or transmitted. • Content Manipulation: The attacker can modify page content, displaying malicious or misleading information. • Redirection or Phishing: The attacker can redirect users to fake pages designed to collect sensitive data.
Affected Host(s)	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding https://0a4100da0455e5ef80882b5000940086.web-security-academy.net DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute https://0a68007703f6b3b0805f265c00a7008b.web-security-academy.net
Remediation	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding 1. Output Encoding: Encode all user-supplied data before rendering it in the HTML context. This prevents special characters from being interpreted as code. Use libraries



	like OWASP's Java Encoder. 2. Input Validation: Restrict user input by validating and sanitizing it to only allow acceptable characters. 3. Content Security Policy (CSP): Implement a strong Content Security Policy to mitigate script injection attacks by blocking unauthorized scripts from executing. 4. HTTPOnly and Secure Cookies: Ensure cookies are marked as HTTPOnly and Secure to reduce the risk of theft via XSS. 5. Auditing and Monitoring: Enable logs and monitoring for abnormal traffic patterns, like suspicious query parameters.
	DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute Avoid Direct Use of User Input in HTML Attributes: Avoid directly inserting user inputs into attributes like img src. Instead, validate and sanitize inputs rigorously. HTML Escaping of Special Characters: Any user input that is used within HTML should be encoded to neutralize special characters (like <, >, &, "). Use safer JavaScript functions: Avoid



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila

College of Informatics and Computer Studies

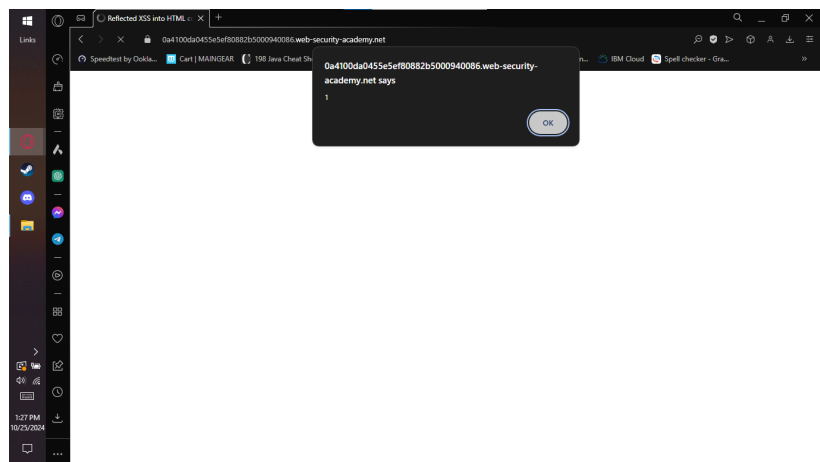
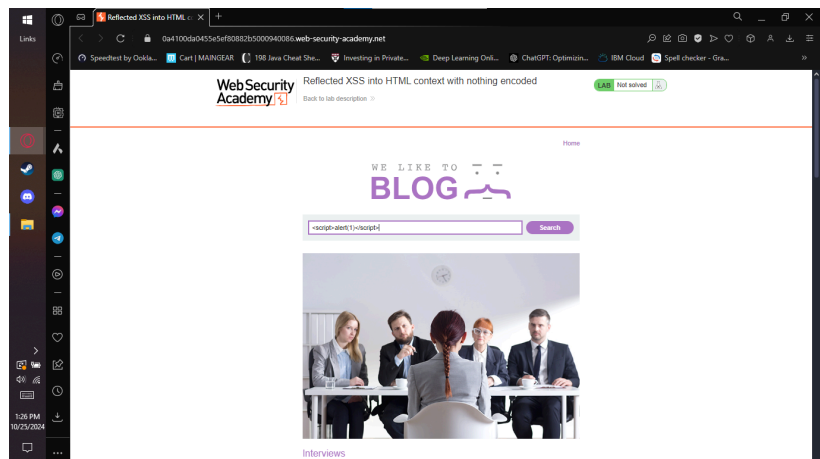


	using document.write or setting innerHTML without sanitization. Use functions liketextContent to safely render text. Content Security Policy (CSP): Implement a CSP header to restrict the execution of unauthorized scripts, reducing the risk of XSS attacks.
External Reference	OWASP XSS Prevention Cheat Sheet PortSwigger DOM XSS Guide CWE-79: Cross-Site Scripting CVSS Calculator
Documentation	Reflected Cross-Site Scripting (XSS) - HTML Context with No Encoding



New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



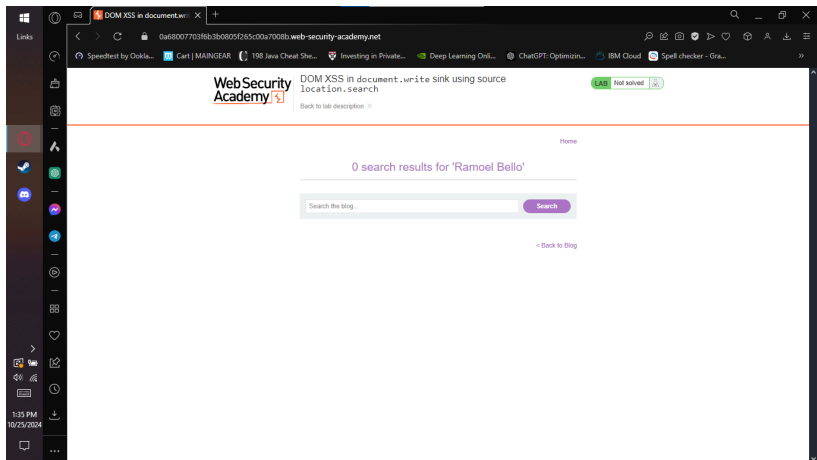
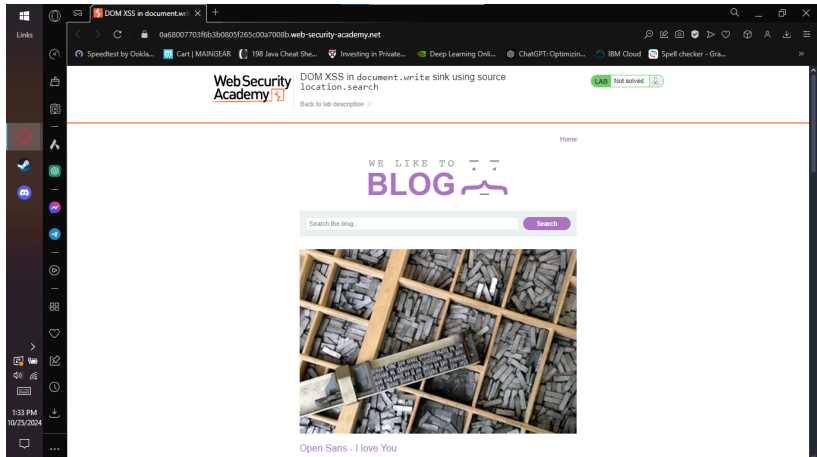


New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



DOM-based Cross-Site Scripting (DOM XSS) - Injection in img src attribute





New Era University

9 Central Ave, New Era, Quezon City, 1107 Metro Manila
College of Informatics and Computer Studies



DOM XSS in document.write sink using source location.search

0 search results for 'Ramoel Bello'

1.5 x 1.5

Search

Back to Blog

DOM XSS in document.write sink using source location.search

0 search results for 'Ramoel Bello'

~>svg onload=alert(1)<

Search

Back to Blog

DOM XSS in document.write sink using source location.search

0 search results for '><svg onload=alert(1)>'

Search the blog...

Search

Back to Blog

DOM XSS in document.write sink using source location.search

0 search results for 'Ramoel Bello'

~>svg onload=alert(1)<

Search

Back to Blog

DOM XSS in document.write sink using source location.search

0 search results for 'Ramoel Bello'

~>svg onload=alert(1)<

Search

Back to Blog

DOM XSS in document.write sink using source location.search

0 search results for '><svg onload=alert(1)>'

Search the blog...

Search

Back to Blog